

Vulnerability Management Sprint Report

Name: Utibe Anthony Akpan

Environment: Wazuh SOC Home Lab

Executive Summary:

A full vulnerability assessment was performed across both endpoints in the SOC home lab — a Windows 11 workstation ("Win11", running Sysmon, Wazuh Agent and Atomic Red Team) and an Ubuntu Linux VM ("Smart-VirtualBox," running Suricata and Wazuh Agent) — using Wazuh's built-in Vulnerability Detection module correlated against the NVD feed. The scan returned 2,888 vulnerability alerts combined across both machines. Findings were prioritized using a combination of CVSS severity, presence in the CISA Known Exploited Vulnerabilities (KEV) catalog, and asset criticality, rather than severity alone — this identified three activelyexploited (KEV-confirmed) vulnerabilities as the top priority regardless of their raw CVSS label. One finding was fully remediated via a kernel update on Ubuntu, and one was mitigated with a compensating control on Windows pending a full patch. As of this report, both P1 remediation actions have been verified, with the remaining findings triaged into backlog tiers for future action.

Phase 1 — Enable Vulnerability Detection:

The Wazuh Vulnerability Detection module was enabled on the Wazuh manager (Kali VM), configured to correlate installed software inventory against a live NVD feed across both the Windows 11 and Ubuntu endpoints.

Configuration

The following block was enabled in the manager's ossec.conf:

```
<vulnerability-detection>

  <enabled>yes</enabled>

  <index-status>yes</index-status>

  <feed-update-interval>60m</feed-update-interval>
```

</vulnerability-detection>

Feed source: NVD. Feed update interval: 60 minutes. Agents covered: Win11 (Windows 11 Home) and the Ubuntu VM (running Suricata).

Verification

- Both agents confirmed "Active" via `agent_control -l`, with syscollector enabled and reporting software inventory.
- Manual inventory sync triggered by restarting both agents and the manager, forcing an immediate syscollector scan cycle.
- Scan cycle completion confirmed: real, CVE-mapped findings appeared in the Events view for the Windows endpoint (initially 1,140, later 1,801 findings) with correct CVE IDs, severities, and package data.

Gap / Challenge — Indexer-Connector TLS Certificate Mismatch

While the scan cycle itself completed successfully and populated Events, the Dashboard and Inventory tabs initially returned no results. Root-cause troubleshooting proceeded as follows:

- Confirmed the `wazuh-states-vulnerabilities-*` index did not exist (`_count` query returned 0 total shards), indicating the inventory-harvester pipeline was not writing to the indexer at all — a separate pipeline from the alerts pipeline behind Events.
- Checked indexer-connector logs directly, which showed persistent "IndexerConnector initialization failed" warnings across every `states-*` index (vulnerabilities, packages, services, users, etc.), not just vulnerabilities — indicating a systemic connector issue rather than a vulnerability-specific bug.
- Tested the manager-to-indexer TLS connection manually with `curl` using the configured client certificate, which returned: "SSL: no alternative certificate subject name matches target hostname/IP".
- Inspected the certificate's Subject Alternative Names directly with `openssl` — none were present.
- Traced this to the original `wazuh-certs-tool.sh` `config.yml`, which had generated all node certificates for 127.0.0.1 rather than the manager's actual LAN IP (192.168.1.102).

Resolution

The certificate config was corrected and certificates regenerated:

```
sed -i 's/127.0.0.1/192.168.1.102/g' config.yml bash
```

```
wazuh-certs-tool.sh -A
```

New indexer, dashboard, and admin certificates (now carrying the correct IP as SAN) were deployed to `/etc/wazuh-indexer/certs/`, `/etc/wazuh-dashboard/certs/`, and `/etc/filebeat/certs/`

respectively, with ownership and permissions corrected for each service account. After restarting the indexer, dashboard, and manager, the TLS handshake succeeded (verified via curl returning a healthy cluster status), and the indexer-connector log showed successful initialization for every states-* index, including wazuh-states-vulnerabilities-kali.

Following this fix, Dashboard and Inventory populated correctly for both endpoints, and the Events pipeline showed a combined 2,888 vulnerability alerts across both agents. **Checkpoint — Status**

Requirement	Status
Vulnerability Detection module enabled and correlating against a current CVE feed	Complete
Both endpoints confirmed reporting inventory data	Complete
Configuration documented (feed source, interval, agents covered)	Complete

Phase 2 — Finding:

Asset	OS	Role / Purpose	Assessment Status
Win11	Windows 11 Home	Endpoint used for attack simulation (Atomic Red Team), with Sysmon and PowerShell script block logging enabled — central to the lab's detection testing	Completed
smart-VirtualBox	Ubuntu Linux	Runs Suricata (network intrusion detection) — the lab's network-based detection sensor	Completed

Both assets are treated as equally critical: Windows generates the attack telemetry the lab is built to detect, while Ubuntu/Suricata is the sensor doing the detecting — compromise of either would undermine the lab's overall detection capability.

Vulnerability Findings

A full inventory scan across both endpoints returned 2,888 vulnerability alerts combined:

Severity	Windows	Ubuntu
Critical	0	470
High	417	2,128
Medium	142	1638
Low	3	81

All High and Critical findings (2,551 total) were cross-referenced programmatically against the CISA Known Exploited Vulnerabilities (KEV) catalog. This surfaced three confirmed activelyexploited vulnerabilities:

CVE	Affected Asset	Severity	CVSS	CISA KEV
CVE-202668820	Win11	High	7.8	Yes
CVE-2023-4863	smart-VirtualBox	High (Wazuh) /Critical (NVD)	9.8	Yes
CVE-202653362	smart-VirtualBox	High	7.8	Yes

Notably, none of Ubuntu's 470 Critical-severity findings appeared in KEV — an important discovery in itself, since it shows CVSS severity alone does not indicate real-world exploitation risk.

Phase 3 — Prioritization

Findings were scored using three factors together — CVSS severity, CISA KEV status, and asset criticality — rather than relying on severity alone, since a Critical CVE with no real-world exploitation can matter less than a High CVE that's actively being exploited.

Tier	Criteria
P1 — Immediate	High/Critical severity AND confirmed in CISA KEV
P2 — This week	Critical severity, not in KEV
P3 — Backlog	High severity, not in KEV

Prioritization Decisions

- **CVE-2026-68820 — P1:** Prioritized despite a High (not Critical) CVSS score because it is confirmed under active exploitation per CISA KEV, and the affected Windows endpoint is central to the lab's attack-simulation and logging workflow.
- **CVE-2023-4863 — P1:** Flagged as "High" by Wazuh's local scanner, but NVD confirms a CVSS base score of 9.8 (Critical); combined with confirmed KEV status, this is the highest-priority finding in the assessment despite the scanner's severity label.
- **CVE-2026-53362 — P1:** Actively exploited per CISA KEV; affects the Ubuntu Suricata sensor, equally critical to the lab's detection capability as the Windows endpoint.
- **CVE-2026-80714 / CVE-2026-80694 — P2:** Critical CVSS scores but not present in KEV; still warrant near-term remediation given their severity and the asset's criticality, but were not prioritized above the confirmed-exploited P1 findings.
- **CVE-2026-62748 (Win11) / CVE-2026-80752 (smart-VirtualBox) — P3:** High

severity, not present in KEV; retained on the backlog tier since there is no evidence of active exploitation and CVSS alone does not justify immediate action ahead of the confirmed-exploited P1 and Critical-but-unexploited P2 findings.

Phase 4 — Remediation:

Finding: CVE-2026-53362

- **Affected asset:** smart-VirtualBox (Ubuntu)
- **Action taken:** Kernel update — upgraded `linux-image-generic-hwe-24.04` and `linux-headers-generic-hwe-24.04` from `v6.17.0-14` to `v7.0.0-31` via `apt`, followed by a reboot.
- **Reason:** This is a KEV-confirmed, actively exploited kernel vulnerability with a permanent patch already available in the standard Ubuntu repository, making a full update the most direct and complete fix.
- **Before:** Vulnerability detected (High severity, confirmed in CISA KEV).
- **After:** Re-scan performed via `syscollector` restart and `alerts-index` query; finding **cleared** (0 hits for this CVE post-patch)

Finding: CVE-2026-68820

- **Affected asset:** Win11 (Windows 11)
- **Action taken:** Compensating control — enabled system-wide exploit mitigations (DEP, SEHOP, ASLR/ForceRelocateImages, CFG, StrictHandle) via PowerShell's `Set-ProcessMitigation`, while the permanent Windows security update was pending installation.
- **Reason:** The full Windows security update required significant download and installation time that the lab VM's available resources could not complete within the assessment window, so an immediate compensating control was applied to reduce exploitability of the underlying use-after-free (CWE-416) condition while the permanent patch continued downloading in the background
- **Before:** No explicit system-level exploit mitigations enforced (DEP, SEHOP, CFG, ASLR all showed NOTSET)
- **After:** Confirmed via `Get-ProcessMitigation` — DEP, SEHOP, CFG, and ASLR now explicitly ON system-wide; permanent patch (Windows Update) still pending completion at time of writing, so the underlying CVE finding itself **remains** present pending a follow-up re-scan once the update completes.

Remaining Risk:

- **CVE-2026-68820** (Windows) — compensating control applied; permanent Windows Update was still downloading/installing at time of writing due to time and resource constraints on the lab VM. A follow-up re-scan is needed once the update completes to confirm the finding clears.
- **~2,542 non-KEV High/Critical findings** (P2/P3 tier) — documented and triaged but not individually remediated in this sprint; recommended as ongoing backlog work.
- **Ubuntu's 470 Critical findings** — none matched CISA KEV, but their volume and severity warrant scheduled patching.
- **Practical exploitability of edge-case kernel CVEs** (e.g., subsystem-specific drivers unlikely to be in active use in this lab) — flagged for further validation rather than treated as confirmed false positives.

Conclusion:

This project successfully stood up vulnerability detection across both lab endpoints, triaged over 2,500 High/Critical findings using a defensible CVSS + KEV + asset-criticality model, and fully or partially remediated the KEV-confirmed P1 findings — one with a complete patch (verified via re-scan) and one with a verified compensating control pending a full update. The next action is to complete the pending Windows Update and re-scan CVE-2026-68820 to confirm full remediation, followed by scheduled patching of the remaining P2/P3 backlog in a future sprint.